

Security+ 5.3 · Third-party Risk Assessment

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 5.3 — Third-party Risk Assessment (11:36)** · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: TPRM: right-to-audit clause (contrato DEIXA tu auditar); supply chain analysis (quem fornece o fornecedor); vendor monitoring (a postura de segurança continuamente).

Highlights que a prova cobra

- TPRM: avaliar, contratar, MONITORAR o fornecedor continuamente
- Right-to-audit: cláusula que deixa tu auditar o fornecedor

Dicas de prova & Cenários Típicos

- 'contract clause allowing security audits of vendor'=right-to-audit

Cenário clássico de exame: ' contrato permite auditoria no fornecedor'=right-to-audit clause.

Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 5.3 — Third-party Risk Assessment)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **Princípio do Menor Privilégio:** Usuários e sistemas devem ter apenas as permissões estritamente necessárias para suas funções corporativas.
- **Defesa em Profundidade (Defense-in-Depth):** Aplicação de múltiplas camadas de controles (técnicos, administrativos, físicos) para evitar que a falha de um exponha todo o ambiente.

Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. Cenário corporativo (Third-party Risk Assessment): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.3), um analista avalia o seguinte requisito técnico: 'TPRM: avaliar, contratar, MONITORAR o fornecedor continuamente'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: TPRM: avaliar, contratar, MONITORAR o fornecedor continuamente...

2. Cenário corporativo (Third-party Risk Assessment): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.3), um analista avalia o seguinte requisito técnico: 'Right-to-audit: cláusula que deixa tu auditar o fornecedor'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Right-to-audit: cláusula que deixa tu auditar o fornecedor...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

3. Cenário corporativo (Third-party Risk Assessment): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.3), um analista avalia o seguinte requisito técnico: 'contract clause allowing security audits of vendor'=right-to-audit'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'contract clause allowing security audits of vendor'=right-to-audit...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

4. Cenário corporativo (Third-party Risk Assessment): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.3), um analista avalia o seguinte requisito técnico: 'contrato permite auditoria no fornecedor'=right-to-audit clause.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'contrato permite auditoria no fornecedor'=right-to-audit clause....
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Third-party Risk Assessment): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.3), um analista avalia o seguinte requisito técnico: 'TPRM: avaliar, contratar, MONITORAR o fornecedor continuamente'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: TPRM: avaliar, contratar, MONITORAR o fornecedor continuamente...

6. Cenário corporativo (Third-party Risk Assessment): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.3), um analista avalia o seguinte requisito técnico: 'Right-to-audit: cláusula que deixa tu auditar o fornecedor'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Right-to-audit: cláusula que deixa tu auditar o fornecedor...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Third-party Risk Assessment): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.3), um analista avalia o seguinte requisito técnico: 'contract clause allowing security audits of vendor'=right-to-audit'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'contract clause allowing security audits of vendor'=right-to-audit...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Third-party Risk Assessment): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.3), um analista avalia o seguinte requisito técnico: "contrato permite auditoria no fornecedor'=right-to-audit clause.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'contrato permite auditoria no fornecedor'=right-to-audit clause....
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Third-party Risk Assessment): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.3), um analista avalia o seguinte requisito técnico: 'TPRM: avaliar, contratar, MONITORAR o fornecedor continuamente'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: TPRM: avaliar, contratar, MONITORAR o fornecedor continuamente...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Third-party Risk Assessment): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.3), um analista avalia o seguinte requisito técnico: 'Right-to-audit: cláusula que deixa tu auditar o fornecedor'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Right-to-audit: cláusula que deixa tu auditar o fornecedor...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRADORES

1) D — Implementar a solução correspondente: TPRM: avaliar, contratar, MONITORAR o fornecedor continuamente....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.3 (Third-party Risk Assessment): TPRM: avaliar, contratar, MONITORAR o fornecedor continuamente.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

2) C — Implementar a solução correspondente: Right-to-audit: cláusula que deixa tu auditar o fornecedor....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.3 (Third-party Risk Assessment): Right-to-audit: cláusula que deixa tu auditar o fornecedor.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

3) C — Implementar a solução correspondente: 'contract clause allowing security audits of vendor'=right-to-audit....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.3 (Third-party Risk Assessment): 'contract clause allowing security audits of vendor'=right-to-audit.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a

responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

4) A — Implementar a solução correspondente: ' contrato permite auditoria no fornecedor' =right-to-audit clause.....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.3 (Third-party Risk Assessment): ' contrato permite auditoria no fornecedor' =right-to-audit clause..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) D — Implementar a solução correspondente: TPRM: avaliar, contratar, MONITORAR o fornecedor continuamente....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.3 (Third-party Risk Assessment): TPRM: avaliar, contratar, MONITORAR o fornecedor continuamente.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) A — Implementar a solução correspondente: Right-to-audit: cláusula que deixa tu auditar o fornecedor....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.3 (Third-party Risk Assessment): Right-to-audit: cláusula que deixa tu auditar o fornecedor.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a

responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) B — Implementar a solução correspondente: 'contract clause allowing security audits of vendor'=right-to-audit....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.3 (Third-party Risk Assessment): 'contract clause allowing security audits of vendor'=right-to-audit.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) A — Implementar a solução correspondente: ' contrato permite auditoria no fornecedor'=right-to-audit clause.....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.3 (Third-party Risk Assessment): ' contrato permite auditoria no fornecedor'=right-to-audit clause..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) C — Implementar a solução correspondente: TPRM: avaliar, contratar, MONITORAR o fornecedor continuamente....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.3 (Third-party Risk Assessment): TPRM: avaliar, contratar, MONITORAR o fornecedor continuamente.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a

responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) A — Implementar a solução correspondente: Right-to-audit: cláusula que deixa tu auditar o fornecedor....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.3 (Third-party Risk Assessment): Right-to-audit: cláusula que deixa tu auditar o fornecedor.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.